

Tópico 01: Conceitos de Segurança

1. Qual é a diferença na aplicação prática entre encriptação simétrica e assimétrica?

A encriptação simétrica é usada para ocultar o conteúdo de grandes blocos de dados ou fluxos contínuos (como ficheiros e mensagens) devido à sua rapidez. A encriptação assimétrica é aplicada apenas a blocos de pequena dimensão, como encriptar chaves simétricas ou valores de hash para assinaturas digitais, por ser muito mais pesada computacionalmente.

2. Por que motivo a defesa contra ataques passivos se foca na prevenção e não na deteção?

Os ataques passivos (como a escuta de rede) não alteram os recursos nem o funcionamento do sistema, o que os torna quase impossíveis de detetar ativamente. Logo, a única defesa viável é a prevenção através da encriptação dos dados em trânsito.

3. Como distingues a integridade de dados orientada à ligação da não orientada à ligação?

A integridade orientada à ligação protege todo um fluxo de mensagens contra anomalias de sequência, como duplicação, reordenação ou repetição. A não orientada à ligação protege apenas uma mensagem individual contra modificações, ignorando o contexto temporal do fluxo.

4. Num modelo de acesso à rede, qual é o papel da função "Gatekeeper"?

Atua como uma sentinela no canal de acesso, tendo a responsabilidade de afastar ameaças externas (como hackers ou malware) antes que estas consigam alcançar os processos e controlos internos do Sistema de Informação.

5. Define "superfície de ataque" e dá dois exemplos práticos.

É o conjunto de todas as vulnerabilidades que podem ser alcançadas e exploradas num sistema. Exemplos incluem portas abertas em servidores web expostos ao exterior e interfaces que processam SQL ou XML vindos do utilizador.

Tópico 02: Firewalls e Deteção de Intrusões

6. Por que razão uma Application-Level Gateway (Proxy) consegue poupar largura de banda, ao contrário de um Packet Filter?

Como opera na camada aplicacional e compreende o tráfego do utilizador, a gateway pode fazer cache dos pedidos (como páginas web), servindo respostas localmente sem ir à Internet, algo que um filtro de pacotes na camada 3 não consegue fazer.

7. Numa topologia "Screened Subnet", qual é a principal vantagem de isolar os servidores públicos numa DMZ?

Garante que o tráfego externo (Internet) apenas consegue aceder aos serviços na DMZ e nunca diretamente à rede interna. Se um servidor na DMZ for comprometido, a rede interna continua protegida por firewalls adicionais.

8. Qual é a utilidade da tabela "nat" e da cadeia "PREROUTING" no IPTables?

A tabela "nat" serve exclusivamente para tradução de endereços. A cadeia "PREROUTING" atua nos pacotes antes de o sistema decidir o seu encaminhamento (routing), sendo ideal para fazer DNAT (redirecionamento de portas).

9. Qual é o grande problema dos IDS baseados em assinaturas (Signature-based)?

Estão limitados a procurar sequências de bytes que correspondam a ataques previamente conhecidos e catalogados. São completamente cegos a novos ataques (Zero-Day) para os quais ainda não existe uma assinatura.

10. Porque é que os Falsos Positivos são um problema grave num IDS baseado em anomalias?

Estes sistemas geram alarmes sempre que o tráfego se desvia de uma linha de base estatística. Falsos positivos constantes obrigam a afinações regulares e podem levar os administradores a ignorar alertas reais ou a bloquear tráfego legítimo.

Tópico 03: Integridade de Dados

11. É possível garantir não-repúdio utilizando apenas um algoritmo MAC?

Não. O MAC usa criptografia simétrica, exigindo uma chave partilhada entre emissor e recetor. Como ambos conhecem a chave e podem gerar um MAC válido, o emissor pode sempre negar que foi ele a criar a mensagem.

12. O que dita a propriedade "collision-free" numa função de hash?

Exige que seja computacionalmente inviável encontrar dois ficheiros ou blocos de entrada completamente diferentes que resultem exatamente no mesmo valor de hash na saída.

13. Qual é o principal objetivo de design do padrão HMAC face a outras abordagens MAC?

Permitir a utilização de funções de hash já existentes (como o SHA-256) de forma direta e sem modificar o seu código nativo, garantindo que o algoritmo de hash possa ser facilmente substituído caso se descubra alguma vulnerabilidade.

14. Na criação de assinaturas digitais, qual é o benefício de usar algoritmos baseados em Curvas Elípticas (ECC) em vez de RSA?

O ECC baseia-se no problema do logaritmo discreto em curvas elípticas, oferecendo o mesmo nível de segurança que o RSA mas com chaves de tamanho substancialmente inferior. Isto torna-o extremamente rápido na assinatura e verificação.

15. Ao armazenar passwords num ficheiro Linux (ex: /etc/shadow), por que se usam funções de hash em vez de encriptação simétrica?

As funções de hash são unidirecionais, não permitindo reverter o valor final para descobrir a password original em texto limpo, mesmo que o ficheiro seja roubado. O sistema apenas compara o hash do input do utilizador com o hash guardado.

Tópico 04: Criptografia Simétrica

16. Explica como os princípios de Difusão e Confusão protegem uma cifra de bloco contra criptoanálise.

A difusão dissipa a estrutura do texto limpo, fazendo com que a alteração de um único bit original afete muitos bits no texto cifrado. A confusão torna a relação entre as estatísticas do texto cifrado e a chave o mais complexa possível.

17. Ao cifrar um ficheiro com o modo ECB (Electronic Codebook), corres um risco severo. Qual é?

O ECB cifra blocos de forma independente com a mesma chave. Blocos de texto limpo idênticos geram blocos cifrados idênticos. Isto falha no princípio da difusão e revela os padrões estruturais dos dados originais (muito visível ao cifrar imagens bitmap).

18. O que acontece à segurança do modo CBC se reutilizares o mesmo Vetor de Inicialização (IV) com a mesma chave?

A reutilização do IV anula a aleatoriedade inicial. Se cifrasses duas mensagens que comecem com o mesmo texto, os primeiros blocos cifrados serão exatamente iguais, permitindo a um atacante inferir padrões e quebrar a segurança.

19. Porque é que o AES abandonou a estrutura da rede de Feistel usada no DES?

O AES procurava uma eficiência extrema e resistência a ataques de força-bruta e criptoanálise linear/diferencial que o DES já não garantia. Em vez de dividir o bloco em duas metades (Feistel), o AES processa o bloco de 128 bits inteiro em paralelo através de substituições e permutações matemáticas complexas.

20. Num cenário de transmissão de streaming de vídeo de alto débito, optarias pelo modo CBC ou CTR?

CTR (Counter Mode). O modo CTR converte a cifra de bloco numa cifra de fluxo e permite processamento totalmente paralelizável, sendo incrivelmente eficiente em hardware e imune à propagação de erros de bloco, ao contrário do CBC que tem de ser calculado sequencialmente.

Tópico 05: Criptografia Assimétrica

21. Para garantir a confidencialidade num sistema RSA, que chave deve ser usada para encriptar os dados?

O emissor deve encriptar a mensagem utilizando a chave pública do destinatário. Assim, garante que apenas o dono da chave privada correspondente conseguirá ler a mensagem.

22. O que dita a propriedade essencial de uma função unidirecional "Trap-door"?

É uma função matemática fácil de calcular numa direção, mas computacionalmente inviável de inverter conhecendo apenas o resultado, a menos que se possua uma informação secreta especial (a trapdoor ou chave privada).

23. Num exame prático de RSA, se os primos forem $p=3$ e $q=7$, qual é o valor do totiente $\varphi(n)$ usado para calcular a chave privada?

Sendo a fórmula $\varphi(n) = (p-1) \times (q-1)$, teríamos $(3-1) \times (7-1)$, ou seja, $2 \times 6 = 12$.

24. O que impede um atacante de calcular a chave privada d conhecendo a chave pública e e o módulo n ?

Para calcular d , o atacante precisa de descobrir o valor da função totiente $\varphi(n)$. Para isso, tem de descobrir os números primos originais p e q que compõem n . O processo de fatorização de inteiros para números grandes (ex: 1024 bits) é computacionalmente inviável na prática.

25. É falso afirmar que a encriptação assimétrica veio tornar a simétrica obsoleta. Porquê?

A criptografia assimétrica baseia-se em operações matemáticas pesadas e chaves enormes, tornando a cifra de grandes volumes de dados demasiado lenta para ser prática. Serve sobretudo para gerir chaves secretas e assinar digitalmente.

Tópico 06: Gestão de Chaves e Autenticação

26. No protocolo Kerberos, por que razão uma falha de sincronização de relógios (NTP) deita abaixo o serviço de autenticação?

O Kerberos combate ataques de repetição (replay attacks) exigindo que os clientes coloquem um carimbo de tempo (timestamp) dentro dos Autenticadores. Se os relógios do cliente e do servidor estiverem muito desfasados, o servidor rejeita o pacote assumindo que é um ataque antigo.

27. Se o escalonamento manual de chaves simétricas numa rede sem KDC exige $N(N-1)/2$ chaves, quantas são precisas para 1000 nós?

O cálculo seria $1000 \times 999 / 2$, resultando em 499.500 chaves. A inviabilidade prática disto força a utilização de uma hierarquia de chaves gerida por um KDC.

28. Como atua o ataque Man-in-the-Middle (MitM) numa troca simples de chaves públicas sem certificados?

O atacante interceta as mensagens entre a Alice e o Bob e substitui a chave pública de ambos pela sua própria chave pública. A partir daí, o atacante consegue decifrar, ler e re-encriptar todo o tráfego que eles julgavam estar seguro.

29. O que é uma cadeia de certificação X.509?

É o mecanismo que permite a uma entidade confiar no certificado de outra, mesmo que tenha sido emitido por uma Autoridade de Certificação (CA) diferente. Se a CA_1 emitir um certificado atestando a confiança na CA_2 , cria-se um caminho fidedigno até ao certificado final.

30. Qual é a vantagem do OCSP Stapling em servidores Web modernos comparado à validação CRL e OCSP clássica?

Em vez de o cliente perder tempo e sobrecarregar a CA com pedidos para confirmar se o certificado foi revogado, é o próprio servidor Web que obtém atempadamente um recibo OCSP assinado e o entrega (staple) logo no handshake inicial.

Tópico 07: Web and Transport-Level Security

31. Ao nível da pilha TCP/IP, porque se diz que o IPSec é transparente para as aplicações, mas o TLS não é nativamente?

O IPSec corre na camada de rede (Camada 3), cifrando os pacotes IP antes de subirem para a aplicação. O TLS corre na camada de transporte sobre TCP, exigindo que a aplicação saiba lidar com a biblioteca criptográfica (daí usar-se HTTPS em vez de HTTP).

32. Qual a principal vantagem de usar Diffie-Hellman Efémero (DHE) no handshake TLS em vez de RSA?

O DHE garante Confidencialidade Perfeita (Forward Secrecy). Como as chaves de sessão são descartadas após o handshake, mesmo que um atacante roube a chave privada permanente do servidor no futuro, não conseguirá decifrar o tráfego capturado no passado.

33. No protocolo TLS, porque não se utiliza o "pre-master secret" diretamente para cifrar os dados?

O pre-master secret tem de ser misturado numa função pseudoaleatória (PRF) com os nonces (números aleatórios) do Cliente e do Servidor para gerar o Master Secret. Isto garante entropia fresca de ambas as partes e impede ataques de repetição.

34. Como consegues proteger o acesso a uma base de dados remota insegura que apenas aceita tráfego TCP sem encriptação?

Usando Port Forwarding local via SSH (`ssh -L`). Abres um túnel seguro para o servidor remoto e mapeias um porto local para o porto do serviço. A tua máquina fala localmente e o SSH encarrega-se de encapsular o tráfego na rede.

35. Porque é que o conceito de "Sessão" no TLS é crucial para a performance das aplicações web modernas?

O TLS permite associar um estado (como as chaves de sessão) e partilhá-lo por múltiplas ligações subsequentes. Isto evita a sobrecarga computacional de repetir o pesado Handshake assimétrico sempre que o cliente pede um novo recurso web.

Tópico 08: IP Security (IPSec)

36. Um router a meio do caminho efetua Source NAT. Que cabeçalho IPSec se deve evitar e porquê?

O Authentication Header (AH). Como o AH garante a integridade de todo o pacote IP (incluindo o IP de origem), se o router alterar esse IP devido ao NAT, o destino descarta o pacote assumindo que foi adulterado. Deve ser usado o ESP.

37. Num cenário de túnel VPN entre duas filiais (Gateway-a-Gateway), qual o modo IPSec apropriado e o seu impacto nos cabeçalhos?

O Modo Túnel. O pacote IP original da máquina do funcionário é completamente encapsulado e encriptado (ESP) dentro de um novo pacote IP gerado pelo router. Isto esconde os endereços internos da empresa face à Internet.

38. Qual a distinção na atuação da Security Policy Database (SPD) e da Security Association Database (SAD)?

A SPD contém as regras de negócio (seletores como IP e porta) para decidir o que fazer ao tráfego (Descartar, Bypass ou Proteger). Se a ação for proteger, consulta-se a SAD, que guarda as chaves criptográficas reais e algoritmos (Security Associations) atribuídos àquela ligação através do SPI.

39. Como se processa o mecanismo anti-replay do IPSec face à natureza instável da rede IP?

O IPSec usa um contador de sequência e uma janela deslizante. Se um pacote autenticado chegar com um número inferior à margem esquerda da janela (atrasado demais ou repetido maliciosamente), é imediatamente descartado.

40. Numa política IPSec que exija encriptação e troca contínua de chaves, qual é o papel do protocolo IKE?

O Internet Key Exchange automatiza a criação on-demand das Security Associations e a distribuição de chaves secretas baseada no algoritmo Diffie-Hellman, algo essencial já que a configuração manual de chaves num ambiente IP distribuído seria impraticável.

Tópico 09: Segurança de Email

41. Se o meu domínio já assina mensagens com DKIM, continuo a ter utilidade para o S/MIME?

Sim. Têm propósitos diferentes. O DKIM opera ao nível dos MTAs para assinar o email, provando que a origem do domínio é real e combatendo spoofing e spam. O S/MIME atua no MUA do utilizador para encriptar e certificar end-to-end o conteúdo do ficheiro contra leitura não autorizada.

42. O que acontece a um email de phishing se a política SPF no DNS do remetente tiver o modificador "-all"?

A diretiva de rejeição estrita ("-all") indica aos servidores de receção que qualquer email cujo IP de origem não esteja explicitamente listado no registo TXT do SPF não está autorizado a enviar pelo domínio e deve ser descartado.

43. O que distingue a segurança garantida pelo STARTTLS da garantida pelo PGP?

O STARTTLS encripta apenas o canal de transporte (SMTP sobre TLS) entre dois servidores, protegendo os pacotes de escuta na rede. O PGP encripta o próprio corpo da mensagem de forma persistente, garantindo que mesmo os administradores dos servidores não conseguem ler o texto.

44. Qual é o papel essencial do protocolo DMARC face ao SPF e DKIM?

O DMARC estabelece a política final e os relatórios. Ele sinaliza aos servidores recetores o que devem exatamente fazer (rejeitar, quarentena, etc.) caso o email falhe as validações de alinhamento das assinaturas do DKIM e os IPs do SPF.

45. Por que razão a tecnologia DANE tenta combater as limitações do sistema de Autoridades de Certificação (CAs)?

O DANE baseia a confiança na segurança fornecida pelo DNSSEC. O objetivo é substituir a dependência de Autoridades de Certificação externas (que podem ser hackeadas ou coibidas), associando os certificados X.509 diretamente aos nomes de domínio através de assinaturas no DNS local.

Tópico 10: Segurança Aplicacional

46. Numa API REST, o que caracteriza um ataque Insecure Direct Object Reference (IDOR)?

Ocorre quando a aplicação verifica se o utilizador fez login, mas não autoriza rigorosamente se o recurso lhe pertence. O atacante altera diretamente um parâmetro (ex: alterar `user_id=1` para `user_id=2`) e consegue extrair informações de terceiros contornando a falha de Broken Access Control.

47. Qual é a falha estrutural que despoleta os ataques de injeção como o SQLi?

A injeção ocorre sempre que input não confiável do utilizador é diretamente concatenado ou interpretado como comandos por um interpretador (como uma base de dados) sem parametrização ou validação prévia do servidor.

48. Explica a diferença de impacto entre um ataque de XSS Refletido e um XSS Armazenado (Stored).

O XSS Refletido requer que a vítima clique num link malicioso para que o script execute no seu browser. O XSS Armazenado é muito mais gravoso: o script fica gravado no servidor (ex: comentário num fórum) e é executado automaticamente no browser de todas as vítimas que visitem a página infetada.

49. De que forma uma falha de "Insecure Design" pode potenciar um ataque de Força-Bruta num sistema OTP?

Se não for arquitetada uma barreira como limites de taxa de submissão (rate limiting) ou bloqueio após x tentativas falhadas, um atacante consegue enviar as dez mil combinações possíveis de um PIN de 4 dígitos em segundos e assumir a conta legitimamente.

50. Como é que o abuso do parâmetro `alg:none` num JSON Web Token (JWT) permite a escalada de privilégios?

Se o backend da aplicação aceitar tokens de forma negligente, um atacante pode decodificar o JWT, alterar as suas permissões para "admin", mudar o algoritmo do cabeçalho para "none" e enviar de volta. A aplicação processa o token forjado sem verificar a assinatura matemática do servidor e dá acesso total.

Exame 2021

1. Considera as soluções de segurança de email atualmente usadas na Internet. Se um determinado domínio estiver a usar DKIM (DomainKeys Identified Mail), isso torna desnecessário o uso de S/MIME pelos utilizadores do mesmo domínio? Justifica.

O uso de DKIM não torna o S/MIME desnecessário. O DKIM apenas garante que o email foi enviado por servidores autorizados do domínio e assegura integridade ao nível do domínio (lado servidor). O S/MIME fornece segurança end-to-end entre utilizadores, garantindo confidencialidade, integridade, autenticação e não repúdio do conteúdo da mensagem, independentemente dos servidores intermédios. São mecanismos complementares que operam em níveis diferentes.

2. Considera o algoritmo de cifra simétrica DES (Data Encryption Standard). Qual é a relação entre o efeito avalanche observado neste algoritmo e os princípios definidos na estrutura de Feistel para tornar ataques de criptanálise mais difíceis? Justifica.

O efeito avalanche no DES resulta diretamente da estrutura Feistel, que divide o bloco em duas metades e aplica várias rondas de substituição, permutação e XOR com funções não lineares. Pequenas alterações na entrada propagam-se através das rondas seguintes, espalhando-se por todo o bloco (difusão e confusão), o que torna a relação entre entrada e saída altamente não linear e dificulta ataques de criptanálise.

3. Considera o modo de operação CBC (Cipher Block Chaining). Neste modo, é aconselhável reutilizar um valor de IV (Initialization Vector) com a mesma chave de encriptação? Justifica.

Não é aconselhável reutilizar o mesmo IV no modo CBC com a mesma chave. O IV introduz aleatoriedade no primeiro bloco. Se for reutilizado, mensagens iguais podem gerar padrões iguais no primeiro bloco cifrado, permitindo a um atacante inferir informação estatística sobre os dados e comprometendo a confidencialidade.

5. Considera o protocolo IPSec, o cabeçalho de segurança ESP e o modo de operação em túnel. Descreve um cenário de aplicação onde dois túneis VPN com encriptação (ambos usando ESP) são combinados de forma incorreta. Justifica.

Dois túneis IPSec com ESP em modo túnel tornam-se inválidos quando são aplicados de forma redundante entre os mesmos endpoints sem necessidade lógica, originando encapsulamento duplo desnecessário. Isto aumenta o overhead, pode causar conflitos na aplicação de Security Associations (SA) e políticas SPD e dificulta o correto processamento de encapsulamento e desencapsulamento dos pacotes.

6. Por que razão os códigos MAC (Message Authentication Code) não conseguem garantir não repúdio? Justifica.

O MAC não garante não repúdio porque utiliza uma chave secreta partilhada entre emissor e recetor. Como ambos conhecem a mesma chave, qualquer um pode gerar o mesmo código de autenticação, não existindo prova criptográfica única de autoria da mensagem.

7. No protocolo Kerberos, por que razão o relógio dos sistemas participantes tem de estar sincronizado ou, pelo menos, com um desvio muito pequeno? Justifica.

O Kerberos utiliza timestamps nos tickets para prevenir ataques de replay e definir a validade temporal das credenciais. Se os relógios não estiverem sincronizados, tickets válidos podem ser rejeitados ou tickets expirados podem ser aceites, comprometendo a segurança do sistema. Por isso, é necessária sincronização rigorosa dos relógios com pequena margem de erro entre os sistemas.

Exame 2022

1. Um operador de serviços de email suporta DKIM. Quais as vantagens para os utilizadores finais? Justifique a sua resposta.

O DKIM permite que os utilizadores finais tenham uma verificação criptográfica de que o email foi enviado por um servidor autorizado do domínio e que o conteúdo não foi alterado em trânsito. Isto reduz significativamente spoofing de domínio e ataques de phishing baseados em falsificação de remetente, aumentando a confiança na origem da mensagem. No entanto, o DKIM atua ao nível do domínio e infraestrutura de transporte, não garantindo segurança end-to-end entre utilizadores, pelo que não substitui mecanismos como S/MIME.

2. O IPSec suporta dois modos de funcionamento: AH (Authentication Header) e ESP (Encapsulated Security Payload). Em que situações é aconselhável a utilização de cada um dos modos? Justifique.

O AH é aconselhável em cenários onde se pretende apenas integridade e autenticação do pacote IP, incluindo proteção do cabeçalho IP, sem necessidade de confidencialidade. É mais adequado em ambientes controlados onde encriptação não é necessária, mas é crítico detetar alterações ao pacote.

O ESP é o modo preferencial em cenários reais de comunicação insegura (VPNs e Internet), pois fornece confidencialidade, integridade e autenticação. Ao encriptar o payload (e opcionalmente autenticar), protege o conteúdo contra leitura e manipulação, sendo o modo dominante em IPSec moderno.

3. O HMAC é de utilização obrigatória em diversas soluções de segurança IP, apesar de não garantir não repudição. Concorda com esta obrigatoriedade? Justifique a sua resposta.

Sim, concordo com a obrigatoriedade do HMAC em protocolos como IPSec e TLS, pois o seu objetivo principal é garantir integridade e autenticação eficiente com baixo custo computacional, adequado para comunicação de alto débito. Apesar de não fornecer não repudição devido ao uso de chave secreta partilhada, isso não é requisito nestes contextos, onde o foco é proteção contra alteração e falsificação em tempo real entre entidades já autenticadas.

4. O DNSSEC é uma possível abordagem para impedir a recolha de informação realizada na primeira fase de auditoria remota. Concorda com esta afirmação? Justifique.

Não concordo. O DNSSEC não impede a fase de recolha de informação (reconhecimento). O seu objetivo é garantir autenticidade e integridade das respostas DNS através de assinaturas digitais, prevenindo ataques de spoofing e cache poisoning. Contudo, um atacante continua a poder consultar registos DNS publicamente e recolher informação sobre domínios, subdomínios e infraestrutura.

5. São usadas principalmente duas abordagens de encriptação simétrica: 3DES e AES.

a) Justifique em que situações é recomendável a utilização de cada uma das abordagens.

O 3DES apenas é recomendável em sistemas legados onde não é possível migração imediata, devido à compatibilidade com infraestruturas antigas. Apresenta baixa performance e menor nível de segurança moderna.

O AES é o padrão atual recomendado, sendo adequado para todos os sistemas novos, oferecendo maior segurança criptográfica, melhor desempenho e suporte eficiente a hardware moderno.

b) Que modo(s) de cifra por blocos recomenda para cada uma das abordagens em termos de segurança e performance? Justifique a sua resposta.

Para AES, recomenda-se principalmente CTR ou GCM, pois são modos modernos, paralelizáveis e eficientes. O GCM ainda acrescenta autenticação (AEAD), sendo ideal para sistemas modernos como TLS.

Para 3DES, quando inevitável, utiliza-se CBC, embora com limitações de desempenho e necessidade de IV aleatório único, sendo menos eficiente e menos seguro comparado com modos modernos

Exame 2023

1. Considera as soluções de segurança de email usadas na Internet. O que distingue o PGP e o S/MIME na forma como implementam autenticação e não repúdio nas mensagens transmitidas? Justifica.

O S/MIME baseia-se numa infraestrutura PKI com certificados X.509 emitidos por Autoridades de Certificação (CA), o que permite autenticação forte da identidade do emissor e suporte formal a não repúdio através de assinaturas digitais validadas por terceiros confiáveis.

O PGP utiliza um modelo descentralizado (Web of Trust), onde a autenticação resulta de assinaturas cruzadas entre utilizadores. Também permite assinaturas digitais e não repúdio técnico, mas com menor formalização jurídica, pois a confiança não depende de uma CA central.

2. Considera a estrutura de Feistel usada em algoritmos de cifra simétrica por blocos. Quais são as características desta estrutura que garantem o princípio da difusão? Justifica.

A estrutura Feistel garante difusão através da aplicação iterativa de múltiplas rondas onde cada bloco é dividido em duas metades e combinado com funções não lineares, XOR e permutações. Cada ronda faz com que uma alteração localizada num bit do input se propague progressivamente por todo o bloco ao longo das rondas, assegurando que a saída depende de forma complexa e distribuída de todos os bits de entrada.

3. Considera a utilização do modo CTR (counter) para encriptação simétrica. Consideras este modo adequado para encriptar uma sessão de comunicação com elevado débito (throughput)? Justifica.

Sim, o modo CTR é altamente adequado para comunicações de elevado throughput. Isto deve-se ao facto de transformar a cifra de bloco em uma cifra de fluxo baseada em contador, permitindo pré-computação do keystream, paralelização total das operações de encriptação e ausência de dependência entre blocos, o que elimina gargalos sequenciais e melhora significativamente a performance.

5. Considera o protocolo IPSec, em particular o cabeçalho AH (Authentication Header). É viável usar este cabeçalho para proteger comunicações em modo transporte e simultaneamente utilizar SNAT (Source NAT) num router entre a origem e o destino? Justifica.

Não é viável. O AH inclui proteção de integridade sobre o cabeçalho IP, incluindo os endereços de origem e destino. Como o SNAT altera o endereço IP de origem no router intermédio, a verificação de integridade do AH falha, tornando o pacote inválido.

6. Compara as listas de revogação de certificados (CRL) e o protocolo OCSP como métodos para verificar o estado de revogação de certificados na infraestrutura de chave pública X.509. Discute vantagens e desvantagens de cada método relativamente à escalabilidade, eficiência na atualização da informação e facilidade de utilização.

As CRLs consistem em listas completas de certificados revogados publicadas periodicamente. Têm baixa eficiência de atualização, pois podem ficar desatualizadas entre publicações e tornam-se pesadas em ambientes de grande escala, mas permitem verificação offline.

O OCSP permite verificar em tempo real o estado de um certificado, sendo mais eficiente na atualização da informação e mais escalável em termos de manutenção de estado, mas depende de conectividade constante e introduz latência e carga no servidor OCSP.

7. Considera o protocolo RSA. Descreve como este protocolo introduz o conceito de “função unidirecional com trapdoor” e o seu papel na segurança.

O RSA baseia-se numa função unidirecional com trapdoor: é computacionalmente fácil calcular $C = M^e \bmod n$, mas extremamente difícil inverter essa operação sem a chave privada. A fatorização de n em p e q constitui o “trapdoor” matemático que permite ao detentor da chave privada calcular d e inverter a função de forma eficiente, garantindo a segurança do sistema.

Exame 2024

1. Considera as soluções de segurança de email usadas na Internet. O uso do DKIM para assinar mensagens elimina a necessidade de PGP? Justifica.

Não. O DKIM não elimina a necessidade de PGP. O DKIM apenas garante autenticação e integridade ao nível do domínio (servidor emissor), validando que o email foi enviado por infraestrutura autorizada. O PGP fornece segurança end-to-end entre utilizadores, incluindo confidencialidade, autenticação e não repúdio ao nível do conteúdo da mensagem. Assim, atuam em camadas diferentes e são complementares.

2. Considera que queres garantir confidencialidade e integridade de dados armazenados como registos numa base de dados. Que algoritmo(s) usarias e em que modo? Justifica.

Para confidencialidade utilizaria um algoritmo de cifra simétrica como AES em modo CBC ou, preferencialmente, GCM.

O AES garante encriptação eficiente dos dados armazenados.

Para integridade utilizaria um mecanismo autenticado como AES-GCM (AEAD) ou, alternativamente, um HMAC sobre os registos.

O modo GCM é o mais adequado porque combina confidencialidade e integridade num único esquema eficiente, reduzindo complexidade e risco de erros de implementação.

3. Considera o uso de IPSec para garantir confidencialidade e autenticação entre dois hosts em redes distintas, interligadas por um router com SNAT. Que cabeçalhos e modo de operação usarias? Justifica.

Usaria o protocolo ESP (Encapsulating Security Payload) em modo túnel.

O ESP garante confidencialidade, autenticação e integridade dos dados. O modo túnel encapsula o pacote IP original dentro de um novo pacote IP, o que evita problemas com SNAT, pois o NAT atua apenas no cabeçalho externo e não interfere na proteção interna do pacote IPSec.

4. Considera o protocolo Kerberos. Qual é o papel do Authenticator neste protocolo? Justifica.

O Authenticator é um elemento enviado pelo cliente que contém informação como timestamp e identificador de sessão, encriptado com a chave de sessão. O seu objetivo é provar que o cliente é o legítimo detentor do ticket e impedir ataques de replay, garantindo frescura da comunicação.

6. Considera a segurança em redes wireless. Descreve o papel do protocolo 802.1X na segurança de redes wireless. Justifica.

O 802.1X fornece controlo de acesso baseado em autenticação antes de permitir ligação à rede. Atua como um mecanismo de port-based network access control, utilizando um servidor de autenticação (normalmente RADIUS) para validar credenciais do utilizador ou dispositivo antes de conceder acesso à rede Wi-Fi, aumentando a segurança contra acessos não autorizados.

7. Compara HMAC com assinaturas digitais no que diz respeito a integridade, autenticação e não repúdio. Justifica.

O HMAC garante integridade e autenticação entre partes que partilham uma chave secreta, sendo eficiente e usado em comunicações de rede, mas não garante não repúdio porque ambas as partes podem gerar o mesmo código.

As assinaturas digitais garantem integridade, autenticação e também não repúdio, pois usam chave privada para assinar e chave pública para verificar, permitindo prova criptográfica de autoria.

8. Considera o uso de IPTables e Suricata. Descreve o papel do modo inline neste contexto. Justifica.

No modo inline, o Suricata atua em linha com o tráfego, analisando pacotes em tempo real e podendo bloquear ou permitir tráfego diretamente antes de chegar ao sistema alvo. Em conjunto com IPTables, o tráfego é forçado a passar pelo motor de inspeção, permitindo deteção e prevenção ativa de ataques (IDS + IPS), aumentando a capacidade de resposta em comparação com apenas monitorização passiva.

Exame 2025

2. O domínio “acme.pt” está a sofrer ataques de email spoofing e ainda não utiliza DKIM nem DMARC. Explique como estes mecanismos podem ser usados para proteger o domínio contra este tipo de ataque. Justifique.

O DKIM permite assinar criptograficamente os emails enviados pelo domínio acme.pt, garantindo integridade do conteúdo e autenticidade do domínio emissor através de uma assinatura validada por DNS. O DMARC complementa este mecanismo ao definir políticas de autenticação baseadas nos resultados de SPF e DKIM, permitindo ao domínio especificar como os servidores recetores devem tratar mensagens que falhem validação, como rejeição ou quarentena. Em conjunto, estes mecanismos reduzem significativamente ataques de spoofing ao dificultar a falsificação do campo “From”.

3. Considere um cenário onde se pretende garantir confidencialidade, integridade e autenticação entre dois hosts localizados em redes distintas, utilizando IPsec. O host A tem IP público e o host B encontra-se numa rede interna com NAT. O gateway realiza SNAT. Indique que cabeçalhos e modo do IPsec devem ser utilizados e justifique.

O cenário mais adequado é o uso do protocolo ESP em modo túnel. O ESP fornece confidencialidade através da encriptação do payload, bem como integridade e autenticação dos dados transmitidos. O modo túnel encapsula o pacote IP original dentro de um novo pacote IP exterior, permitindo que o NAT altere apenas o cabeçalho externo sem comprometer a integridade da proteção IPsec. O AH não é adequado neste contexto porque protege também o cabeçalho IP, sendo incompatível com alterações introduzidas pelo NAT.

4. Considere os princípios de confusão e difusão definidos por Claude Shannon no contexto da criptografia simétrica. Explique como estes princípios são implementados em algoritmos modernos como o AES e qual o papel do efeito avalanche.

Os princípios de confusão e difusão são fundamentais na segurança de cifras modernas. A confusão torna a relação entre a chave e o texto cifrado complexa e não linear, enquanto a difusão garante que cada bit do texto original influencia muitos bits do resultado cifrado. No AES, estes princípios são implementados através de operações como substituição não linear (SubBytes), permutação (ShiftRows), mistura linear (MixColumns) e combinação com chave (AddRoundKey), repetidas ao longo de várias rondas. O efeito avalanche assegura que pequenas alterações na entrada produzem grandes alterações no output, reforçando a resistência contra ataques estatísticos e diferenciais.

5. Um servidor web está configurado para suportar HTTPS com um certificado emitido por uma autoridade de certificação “Very safe CA”. No entanto, o browser apresenta um aviso de segurança indicando que o certificado não é confiável, apesar de a “Very safe CA” ser uma autoridade intermédia assinada por uma root CA já confiável pelo browser. Explique a razão deste problema e como pode ser resolvido.

O problema ocorre porque o navegador não consegue validar a cadeia de certificação completa até uma autoridade raiz confiável. Apesar de a “Very safe CA” ser uma CA intermédia válida, o servidor pode não estar a enviar o certificado intermédio necessário para ligar a CA intermédia à root CA já confiável pelo browser. Assim, a cadeia de confiança fica incompleta e o certificado é rejeitado. A solução deve ser aplicada no lado do servidor, configurando corretamente o envio da cadeia completa de certificados intermédios.

6. Considere o protocolo EAP (Extensible Authentication Protocol) utilizado em redes IEEE 802.11i. Explique o seu papel na segurança de redes Wi-Fi e as suas características de extensibilidade.

O EAP funciona como uma estrutura de autenticação flexível utilizada em redes Wi-Fi seguras, permitindo suportar múltiplos métodos de autenticação sem alterar o protocolo base. A sua principal característica é a extensibilidade, permitindo integrar diferentes mecanismos como passwords, certificados ou tokens, geralmente através de um servidor RADIUS. Isto separa o mecanismo de autenticação da infraestrutura de rede, aumentando a escalabilidade e interoperabilidade.

7. Considere o protocolo Kerberos. Um atacante consegue capturar mensagens trocadas durante a autenticação e pretende reutilizá-las mais tarde para se fazer passar por um utilizador legítimo. Explique como o Kerberos previne este tipo de ataque.

O Kerberos previne ataques de replay através da utilização de timestamps e tickets com tempo de vida limitado. Cada autenticação inclui um Authenticator encriptado com a chave de sessão, que contém informação temporal atual. O servidor valida se o timestamp está dentro de uma janela aceitável e rejeita mensagens repetidas ou fora de tempo, impedindo a reutilização de mensagens capturadas anteriormente.

8. Identifique e descreva duas aplicações práticas onde é necessário combinar funções hash com criptografia assimétrica. Justifique.

Uma aplicação fundamental é a assinatura digital, onde o conteúdo da mensagem é primeiro processado por uma função hash e posteriormente o resumo é assinado com a chave privada do emissor, garantindo integridade, autenticação e não repúdio de forma eficiente. Outra aplicação é o TLS/HTTPS, onde hashes são utilizados para garantir integridade do handshake e assinaturas digitais são usadas para autenticar certificados e parâmetros criptográficos. Esta combinação é necessária porque a criptografia assimétrica diretamente sobre grandes volumes de dados seria computacionalmente ineficiente, sendo o hash usado como redução segura do conteúdo.

IPTables

1. Política base

iptables -P INPUT DROP

iptables -P FORWARD DROP

iptables -P OUTPUT ACCEPT

2. Regras básicas

iptables -A <CHAIN> -p <PROTOCOLO> -s <ORIGEM> -d <DESTINO> --dport <PORTA> -j <ACÇÃO>

- | | |
|--|---|
| • INPUT → tráfego para o próprio host | 1. Escolher CHAIN (INPUT ou FORWARD) |
| • FORWARD → tráfego entre redes | 2. Definir protocolo (TCP/UDP/ICMP) |
| • OUTPUT → tráfego gerado pelo sistema | 3. Definir porta do serviço |
| • ACCEPT → permite | 4. Definir origem e destino |
| • DROP → bloqueia | 5. Aplicar ação (ACCEPT / NFQUEUE / DROP) |
| • NFQUEUE → envia para IDS (Suricata) | 6. Garantir DROP final |

3. NAT

iptables -t nat -A POSTROUTING -s <REDE_INTERNA> -j SNAT --to-source <IP_PUBLICO> ou

iptables -t nat -A PREROUTING -p tcp --dport <PORTA> -j DNAT --to-destination <INTERNO>:<PORTA>

4. IDS (Snort inline)

iptables -A FORWARD -p tcp --dport <PORTA> -j NFQUEUE --queue-num 0

5. Regra final

iptables -A FORWARD -j DROP